

VULNERABILITY ASSESSMENT REPORT

Damn Vulnerable Web Application (DVWA)

Prepared by: ANGELO BOSCO SAMJELA

CIN: FIT/APR26/CS7778

Cyber Security Intern | Future Interns

Institute of Finance Management (IFM), Dar es Salaam, Tanzania

Date: May 05, 2026

TABLE OF CONTENTS

1. EXECUTIVE SUMMARY	3
2. SCOPE AND METHODOLOGY	3
2.1 Target Information.....	3
2.2 Tools Used.....	4
2.3 Methodology.....	4
3. FINDINGS SUMMARY	5
4. DETAILED FINDINGS	5
Finding 1: MySQL/MariaDB Port Exposed (HIGH)	5
Finding 2: Login Page Over HTTP — No HTTPS (HIGH)	7
Finding 4: Directory Browsing Enabled (MEDIUM)	9
Finding 5: Hidden File Found — .git/config Exposed (MEDIUM).....	10
Finding 7: Server Version Information Disclosure (MEDIUM)	12
Finding 8: Cookie Missing Secure & HttpOnly Flags (MEDIUM)	13
Finding 10: Cookie Without SameSite Attribute (LOW)	15
Finding 11: X-Content-Type-Options Header Missing (LOW)	16
5. REMEDIATION SUMMARY	17
6. CONCLUSION	18

1. EXECUTIVE SUMMARY

This Vulnerability Assessment Report presents the findings of a security evaluation conducted against the Damn Vulnerable Web Application (DVWA), a deliberately vulnerable web application deployed locally on Kali Linux. The assessment was conducted as part of the Future Interns Cyber Security Internship Program (Task 1).

Three industry-standard tools were used: Nmap for network and port scanning, OWASP ZAP for web application vulnerability scanning, and Firefox Browser DevTools for HTTP header and cookie analysis. A total of 11 distinct vulnerabilities were identified, including 2 High-risk, 6 Medium-risk, and 3 Low-risk findings.

The most critical findings include an exposed MySQL database port (3306) accessible over the network, and user credentials transmitted over unencrypted HTTP. Immediate remediation is strongly recommended for all High and Medium severity findings.

2. SCOPE AND METHODOLOGY

2.1 Target Information

Target Application	Damn Vulnerable Web Application (DVWA)
Target URL	http://127.0.0.1/dvwa
IP Address	127.0.0.1 (Localhost)
Operating System	Kali Linux (VMware Workstation)
Web Server	Apache 2.4.66 (Debian)
Database	MariaDB 11.8.6
Assessment Date	May 05, 2026
Assessment Type	Passive & Active Vulnerability Assessment

2.2 Tools Used

Tool	Version	Purpose
Nmap	7.98	Network & Port Scanning
OWASP ZAP	2.17.0	Web Application Vulnerability Scanning
Firefox Browser DevTools	Kali Linux Build	HTTP Header & Cookie Analysis

2.3 Methodology

The assessment followed a three-phase approach:

- **Phase 1 — Network Reconnaissance:** Nmap was used with aggressive flags (-sV -sC -A -Pn) to enumerate open ports, running services, and version information.
- **Phase 2 — Web Application Scanning:** OWASP ZAP Automated Scan was launched against the DVWA URL to passively and actively identify web vulnerabilities including missing security headers, exposed files, and insecure configurations.
- **Phase 3 — Manual Header Analysis:** Firefox Browser DevTools (Network tab) was used to manually inspect HTTP response headers and cookie attributes for security misconfigurations.

3. FINDINGS SUMMARY

A total of 11 vulnerabilities were identified. The table below provides an overview:

#	Vulnerability	Source	Risk Level	CWE / Reference
1	MySQL/MariaDB Port Exposed (3306)	Nmap	HIGH	CWE-200
2	Login Page Over HTTP — No HTTPS	ZAP / DevTools	HIGH	CWE-319
3	Content Security Policy (CSP) Not Set	OWASP ZAP	MEDIUM	CWE-693 / WASC-15
4	Directory Browsing Enabled	OWASP ZAP	MEDIUM	CWE-548 / WASC-48
5	Hidden File Found (.git/config)	OWASP ZAP	MEDIUM	CWE-538 / WASC-13
6	Missing Anti-Clickjacking Header	OWASP ZAP	MEDIUM	CWE-1021 / WASC-15
7	Server Version Disclosure (Apache/2.4.66)	Nmap / ZAP / DevTools	MEDIUM	CWE-200 / WASC-13
8	Cookie Missing Secure & HttpOnly Flags	Browser DevTools	MEDIUM	CWE-614 / WASC-13
9	Big Redirect — Sensitive Info Leak	OWASP ZAP	LOW	CWE-201 / WASC-13
10	Cookie Without SameSite Attribute	OWASP ZAP	LOW	CWE-1275 / WASC-13
11	X-Content-Type-Options Header Missing	OWASP ZAP	LOW	CWE-693 / WASC-15
HIGH: 2		MEDIUM: 7	LOW: 3	TOTAL: 12

4. DETAILED FINDINGS

Finding 1: MySQL/MariaDB Port Exposed (HIGH)

Risk Level	HIGH
Port	3306/TCP
CWE	CWE-200: Exposure of Sensitive Information

Tool	Nmap 7.98
------	-----------

Description: Nmap detected that port 3306 (MySQL/MariaDB 11.8.6) is openly accessible on the host. Exposing the database port allows attackers to perform brute-force attacks, extract database credentials, and gain unauthorized access to all application data. In a production environment, the database should never be directly exposed to the network.

Remediation:

- Restrict access to port 3306 using firewall rules (iptables or ufw).
- Configure MySQL to bind only to localhost: bind-address = 127.0.0.1.
- Implement strong password policies and disable remote root login.

```
(angelo@kali)~$ nmap -sV -sC -A -Pn localhost -oN nmap_results.txt
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-05 08:26 -0400
Nmap scan report for localhost (127.0.0.1)
Host is up (0.000046s latency).
Other addresses for localhost (not scanned): ::1
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
80/tcp    open  http         Apache httpd 2.4.66 ((Debian))
|_ http-title: Apache2 Debian Default Page: It works
|_ http-server-header: Apache/2.4.66 (Debian)
3306/tcp  open  mysql?
|_ ssl-cert: Subject: commonName=MariaDB Server
|_ Not valid before: 2026-05-05T10:13:57
|_ Not valid after: 2026-05-02T10:13:57
|_ mysql-info:
|   Protocol: 10
|   Version: 11.8.6-MariaDB-2 from Debian
|   Thread ID: 3197
|   Capabilities flags: 65534
|   Some Capabilities: Support41Auth, InteractiveClient, SupportsLoadDataLocal, DontAllowDatabaseTableColumn, SwitchToSSLAfterHandshake, Speaks41ProtocolOld, Speaks41
ProtocolNew, SupportsTransactions, IgnoreSpaceBeforeParenthesis, IgnoreSigpipes, LongColumnFlag, ODBCClient, ConnectWithDatabase, FoundRows, SupportsCompression, Supp
ortsMultipleResults, SupportsMultipleStatements, SupportsAuthPlugins
|   Status: Autocommit
|   Salt: 5T'c>K@>Vu117U6ZsV3
|   Auth Plugin Name: mysql_native_password
|   _ssl-date: TLS randomness does not represent time
|_ fingerprint-strings:
|   GenericLines:
|     11.8.6-MariaDB-2 from Debian
|     _ghVRz0}
|     J6pS.(!jr"NC
|     mysql_native_password
|     #HY000Proxy header is not accepted from 127.0.0.1
|_ LDAPBindReq:
```

Figure 1: Nmap scan showing open port 3306 (MySQL/MariaDB)

```
#HY000Proxy header is not accepted from 127.0.0.1
LDAPBindReq:
  11.8.6-MariaDB-2 from Debian
  -:ysX?p8
  beTV26Y=bYwh
  mysql_native_password
NULL:
  11.8.6-MariaDB-2 from Debian
  _ghVRz0}
  J6pS.(!jr"NC
  mysql_native_password
afp:
  11.8.6-MariaDB-2 from Debian
  ]515W7JM
  'xIE~)JzKEY
  mysql_native_password
8080/tcp open  ssl/http-proxy (bad gateway)
tls-alpn:
  http/1.1
  h2
ssl-date: TLS randomness does not represent time
http-title: ZAP API UI
fingerprint-strings:
  FourOhFourRequest:
    HTTP/1.1 502 Bad Gateway
    content-type: text/plain; charset=UTF-8
    content-length: 290
    exception occurred while attempting to connect to: https://null/nice%20ports%2C/Tri%6Eity.txt%2ebak
    exception was:
    null: Name or service not known
    following document may be of assistance in resolving this failure:
    https://www.zaproxy.org/faq/why-cant-zap-connect-to-my-website/
  GetRequest:
    HTTP/1.1 502 Bad Gateway
    content-type: text/plain; charset=UTF-8
```

Figure 2: Nmap scan — MariaDB version and capability details

```

HTTP/1.1 502 Bad Gateway
content-type: text/plain; charset=UTF-8
content-length: 255
exception occurred while attempting to connect to: https://null/
exception was:
null: Name or service not known
following document may be of assistance in resolving this failure:
https://www.zaproxy.org/faq/why-cant-zap-connect-to-my-website/
HTTPOptions:
HTTP/1.1 502 Bad Gateway
content-type: text/plain; charset=UTF-8
content-length: 228
exception occurred while attempting to connect to: https://null/
exception was:
null
following document may be of assistance in resolving this failure:
https://www.zaproxy.org/faq/why-cant-zap-connect-to-my-website/
http-open-proxy: Potentially OPEN proxy.
Methods supported: GET HEAD CONNECTION
ssl-cert: Subject: organizationName=ZAP/countryName=xx
Subject Alternative Name: IP Address:127.0.0.1
Not valid before: 2026-04-05T12:27:43
Not valid after: 2027-04-08T12:27:43
2 services unrecognized despite returning data. If you know the service/version, please submit the following fingerprints at https://nmap.org/cgi-bin/submit.cgi?new-s
ervice :
=====NEXT SERVICE FINGERPRINT (SUBMIT INDIVIDUALLY)=====
SF-Port3306-TCP:V=7.98XI=7KD=5/5KTime=60F0F205XP=x86_64-pc-linux-gnuKr(NUL
SF:!,64,""\0\0\0n11\.\8\6-MariaDB-2\X20from\X20Debian\0_x0c\0\0_gHVRz0}\
SF:0\Xfe\Xff-\x02\0\Xff\x81\x15\0\0\0\0\0\0=0\0\0\0J6pS\_(Ijr\NC\0mysql_n
SF:ative_password\0")&#x2D;GenericLines,9C,""\0\0\0n11\.\8\6-MariaDB-2\X20fr
SF:om\X20Debian\0_x0c\0\0_gHVRz0}\0\Xfe\Xff-\x02\0\Xff\x81\x15\0\0\0\0\0\
SF:0=0\0\0J6pS\_(Ijr\NC\0mysql_native_password\X004\0\0\0x01\Xffj\x04#HY
SF:Q00Proxy\X20header\X20is\X20not\X20accepted\X20from\X20127\.\0\.\0\1")&#x
SF:(LDAPBindReq,64,""\0\0\0n11\.\8\6-MariaDB-2\X20from\X20Debian\0p\X0c\0
SF:0=0=ysX\p8\0\Xfe\Xff-\x02\0\Xff\x81\x15\0\0\0\0\0\0=0\0\00bTV26Y=bYwh

```

Figure 3: Nmap scan — additional port and service fingerprinting

Finding 2: Login Page Over HTTP — No HTTPS (HIGH)

Risk Level	HIGH
CWE	CWE-319: Cleartext Transmission of Sensitive Information
WASC ID	WASC-4
Tool	Browser DevTools / OWASP ZAP

Description: The DVWA application is served entirely over HTTP without TLS/SSL encryption. All data transmitted between client and server including usernames and passwords on the login page is sent in plaintext. A Man-in-the-Middle (MitM) attacker on the same network can intercept and read this traffic using tools such as Wireshark.

Remediation:

- Configure Apache to serve the application over HTTPS using a valid TLS certificate.
- Implement HTTP Strict Transport Security (HSTS) to prevent protocol downgrade attacks.
- Redirect all HTTP traffic to HTTPS using Apache mod_rewrite.

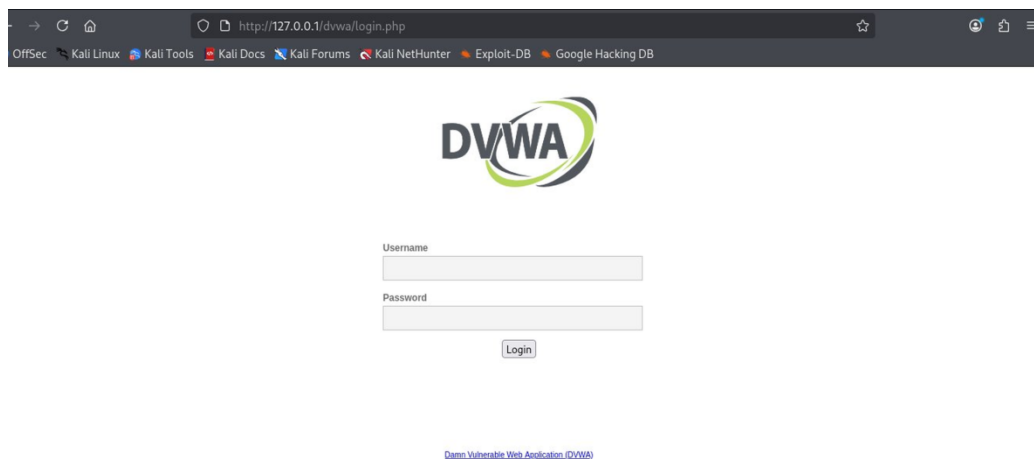


Figure 4: DVWA login page served over HTTP (no HTTPS/padlock)

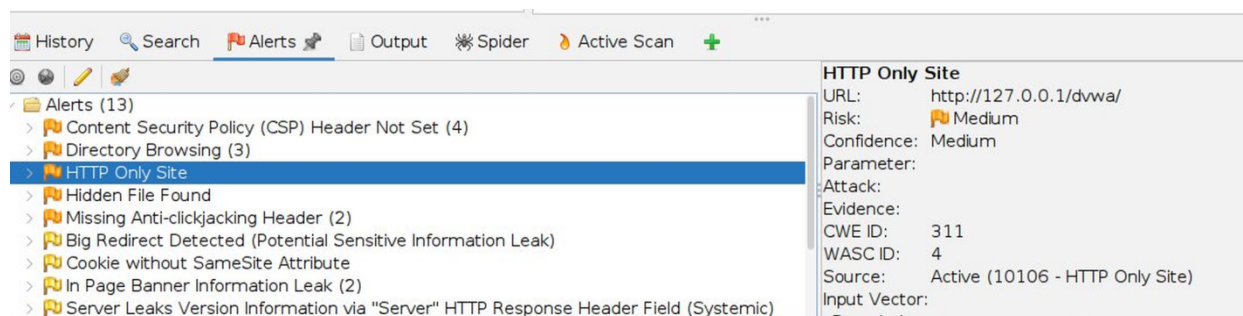


Figure 5: OWASP ZAP confirming HTTP Only Site (CWE-311)

Finding 3: Content Security Policy (CSP) Header Not Set (MEDIUM)

Risk Level	MEDIUM
CWE / WASC	CWE-693 / WASC-15
ZAP Alert ID	10038
Tool	OWASP ZAP 2.17.0

Description: The Content-Security-Policy HTTP response header is not configured. Without CSP, the browser has no instructions on which content sources are trusted, making the application vulnerable to Cross-Site Scripting (XSS) attacks where malicious scripts can be injected and executed in a victim's browser session.

Remediation:

- Add a Content-Security-Policy header in the Apache configuration.
- Start with a strict policy: Content-Security-Policy: default-src 'self'
- Use CSP evaluator tools to test and progressively refine the policy.

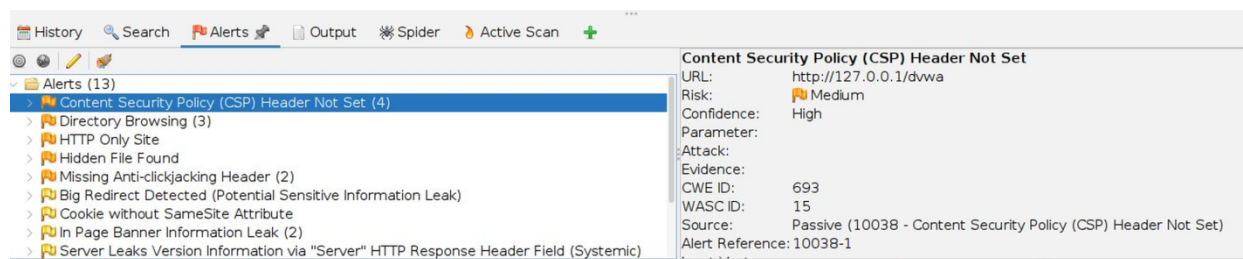


Figure 6: ZAP Alert — CSP Header Not Set (4 instances detected)

Finding 4: Directory Browsing Enabled (MEDIUM)

Risk Level	MEDIUM
CWE / WASC	CWE-548 / WASC-48
Tool	OWASP ZAP 2.17.0

Description: Directory listing is enabled on the web server, allowing unauthenticated users to browse server directories. This exposes internal file structures and may reveal sensitive files, configuration files, backup files, and application source code to potential attackers.

Remediation:

- Disable directory listing in Apache by setting Options -Indexes in the site configuration.
- Protect sensitive directories with appropriate access controls.

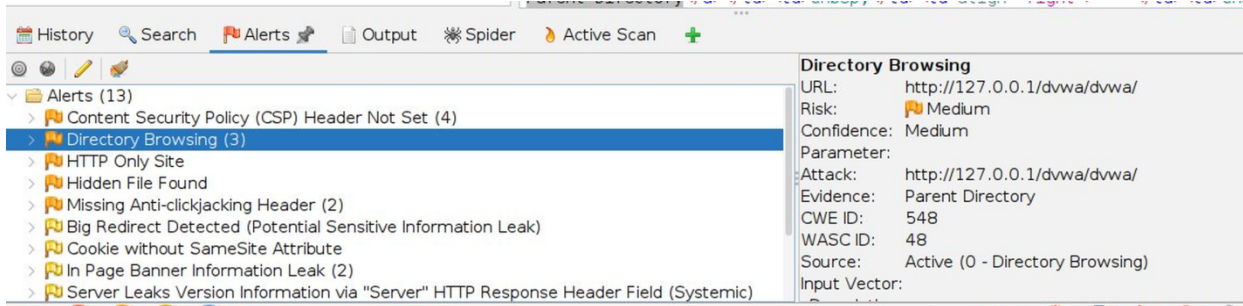


Figure 7: ZAP Alert — Directory Browsing enabled (CWE-548)

Finding 5: Hidden File Found — .git/config Exposed (MEDIUM)

Risk Level	MEDIUM
URL	http://127.0.0.1/dvwa/.git/config
CWE / WASC	CWE-538 / WASC-13
Tool	OWASP ZAP 2.17.0

Description: OWASP ZAP discovered that the .git/config file is publicly accessible. This file contains repository configuration data including remote URLs and branch information. Exposure of .git directories can allow attackers to reconstruct the application source code and discover internal infrastructure details.

Remediation:

- Block access to .git directories in Apache: Deny from all.
- Never deploy applications with .git directories present in the web root.
- Audit the web server for other hidden or sensitive files.

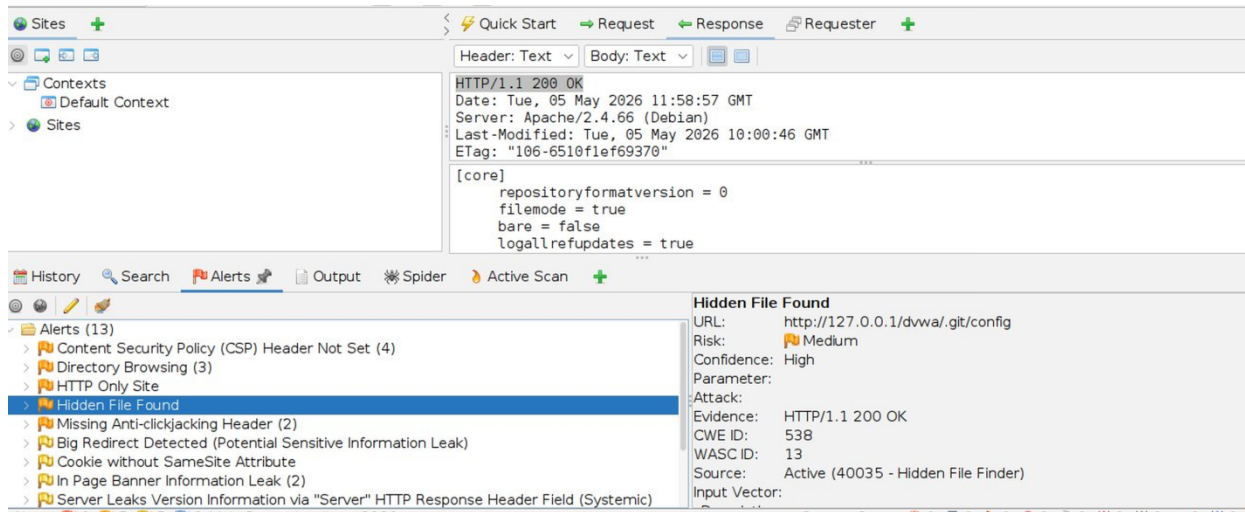


Figure 8: ZAP Alert — Hidden File Found (.git/config accessible)

Finding 6: Missing Anti-Clickjacking Header (MEDIUM)

Risk Level	MEDIUM
CWE / WASC	CWE-1021 / WASC-15
Parameter	x-frame-options
Tool	OWASP ZAP 2.17.0

Description: The X-Frame-Options HTTP response header is absent. Without this header, the application can be embedded inside an iframe on a malicious website, enabling clickjacking attacks where victims are tricked into performing unintended actions while believing they are interacting with a legitimate page.

Remediation:

- Add the header X-Frame-Options: DENY or SAMEORIGIN to all HTTP responses.
- Alternatively, implement the frame-ancestors directive in the Content Security Policy.

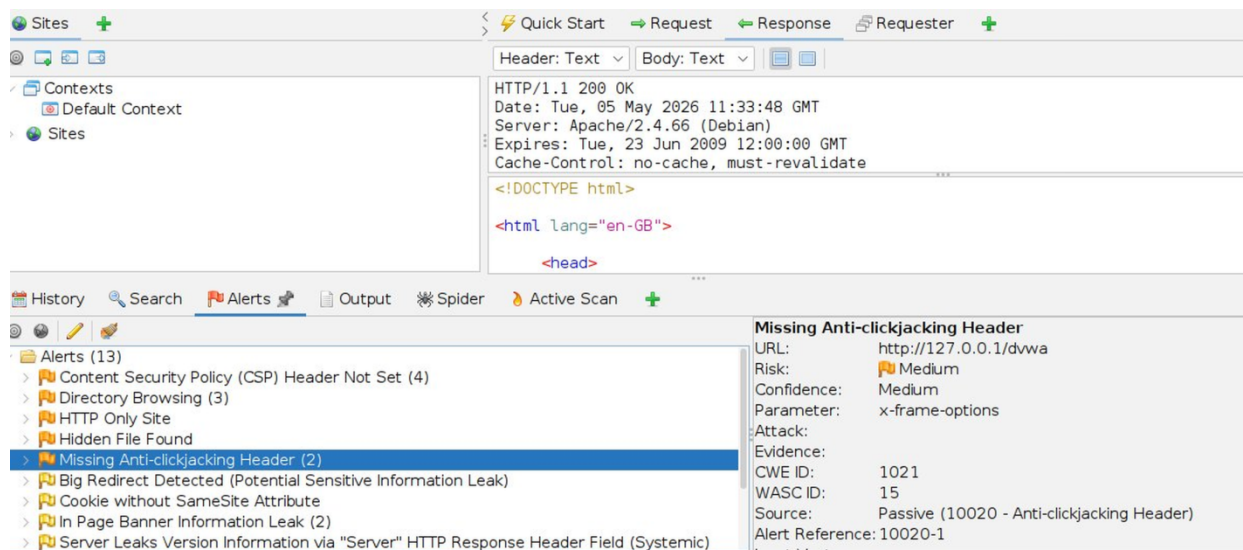


Figure 9: ZAP Alert — Missing Anti-Clickjacking Header (CWE-1021)

Finding 7: Server Version Information Disclosure (MEDIUM)

Risk Level	MEDIUM
Evidence	Apache/2.4.66 (Debian)
CWE / WASC	CWE-200 / WASC-13
Tool	Nmap / OWASP ZAP / Browser DevTools

Description: The HTTP response header exposes the full server version: Apache/2.4.66 (Debian). This information assists attackers in identifying the exact software version and searching for known CVEs (Common Vulnerabilities and Exposures) applicable to that specific version, significantly lowering the effort required to launch a targeted attack.

Remediation:

- Set ServerTokens Prod and Server Signature Off in Apache configuration.
- Restart Apache after making changes: `sudo systemctl restart apache2`
- Keep Apache updated to the latest stable version.

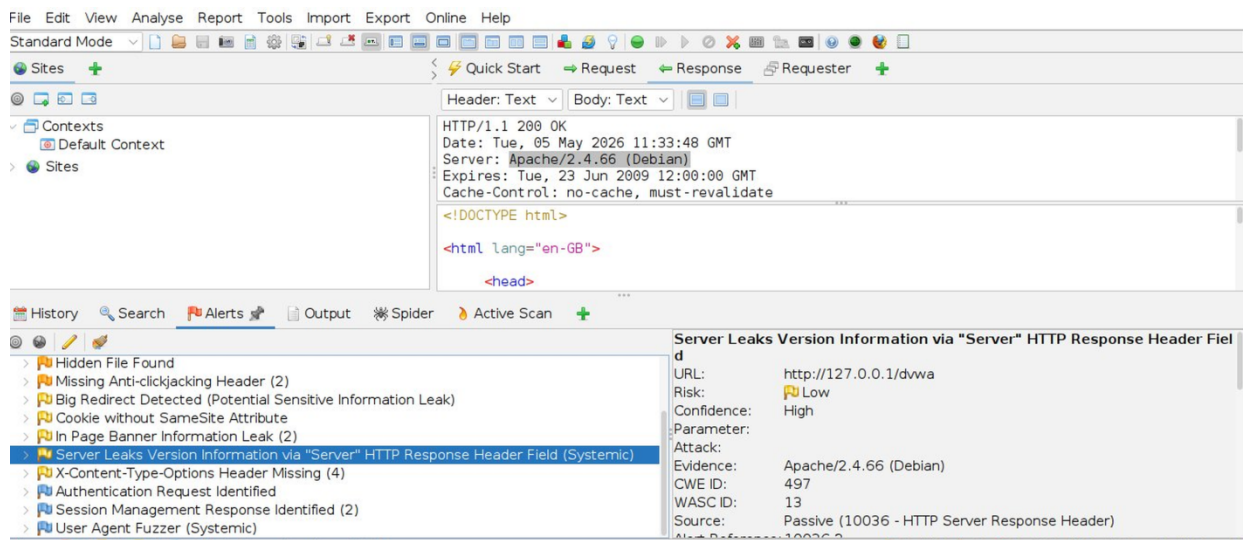


Figure 10: ZAP Alert — Server leaks version via HTTP response header

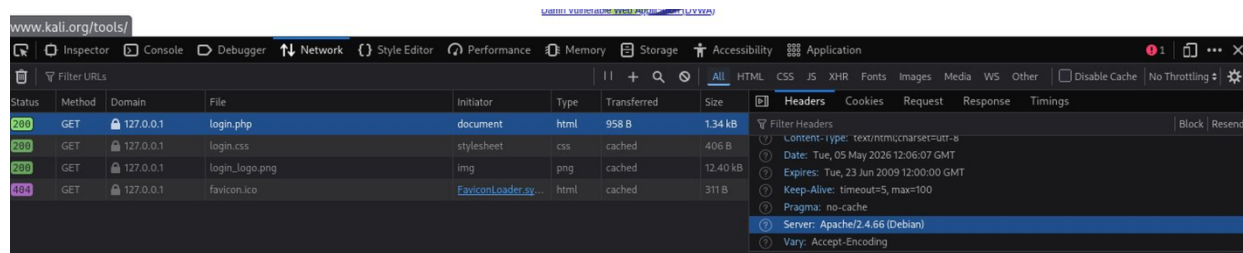


Figure 11: Browser DevTools confirming Apache/2.4.66 version disclosure

Finding 8: Cookie Missing Secure & HttpOnly Flags (MEDIUM)

Risk Level	MEDIUM
CWE / WASC	CWE-614 / WASC-13
Cookie	PHPSESSID / security cookie
Tool	Browser DevTools

Description: Browser DevTools analysis revealed that the PHPSESSID session cookie is transmitted without the Secure flag, meaning it can be sent over unencrypted HTTP. The absence of the Secure flag exposes the session cookie to interception over unencrypted channels, while a missing HttpOnly flag would also allow JavaScript to access and steal the cookie via XSS.

Remediation:

- Set the Secure flag on all cookies to enforce HTTPS-only transmission.
- Set the HttpOnly flag to prevent JavaScript from accessing session cookies.
- Configure in php.ini: session.cookie_secure = 1 and session.cookie_httponly = 1

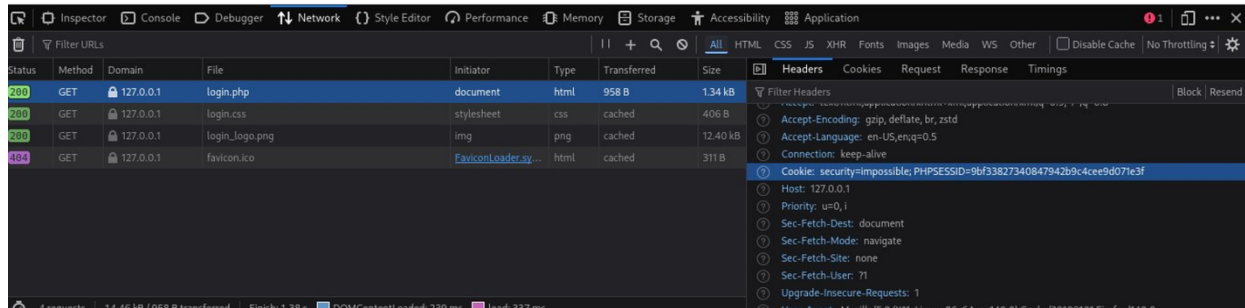


Figure 12: Browser DevTools — Cookie details showing Secure/HttpOnly flag analysis

Finding 9: Big Redirect — Potential Sensitive Information Leak (LOW)

Risk Level	LOW
CWE / WASC	CWE-201 / WASC-13
Tool	OWASP ZAP 2.17.0

Description: A large HTTP 301 redirect response was detected that may contain sensitive information in its response body. Large redirect responses can expose internal paths, session tokens, or other sensitive data to parties intercepting network traffic.

Remediation:

- Ensure redirect responses contain no sensitive data in the body.
- Keep redirect response bodies minimal and remove any unnecessary content.

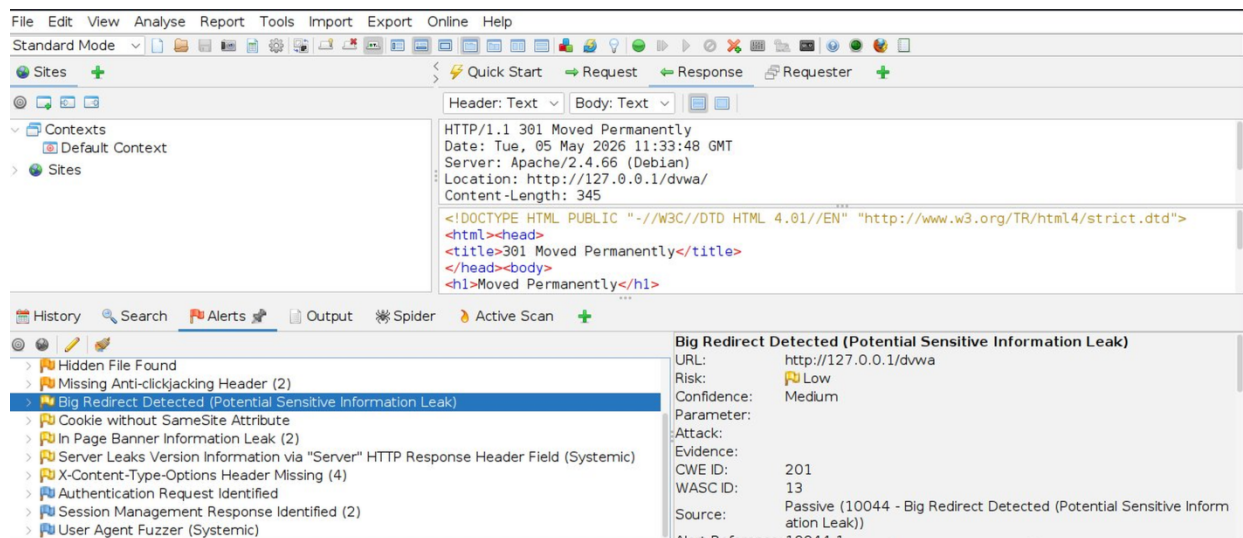


Figure 13: ZAP Alert — Big Redirect Detected (CWE-201)

Finding 10: Cookie Without SameSite Attribute (LOW)

Risk Level	LOW
CWE / WASC	CWE-1275 / WASC-13
Parameter	security cookie
Tool	OWASP ZAP 2.17.0

Description: The security cookie is set without the SameSite attribute. Without this attribute, the cookie is sent with all cross-site requests, making the application susceptible to Cross-Site Request Forgery (CSRF) attacks where an attacker tricks an authenticated user's browser into making unauthorized requests.

Remediation:

- Set SameSite=Strict or SameSite=Lax on all application cookies.
- Combine with anti-CSRF tokens for layered protection.

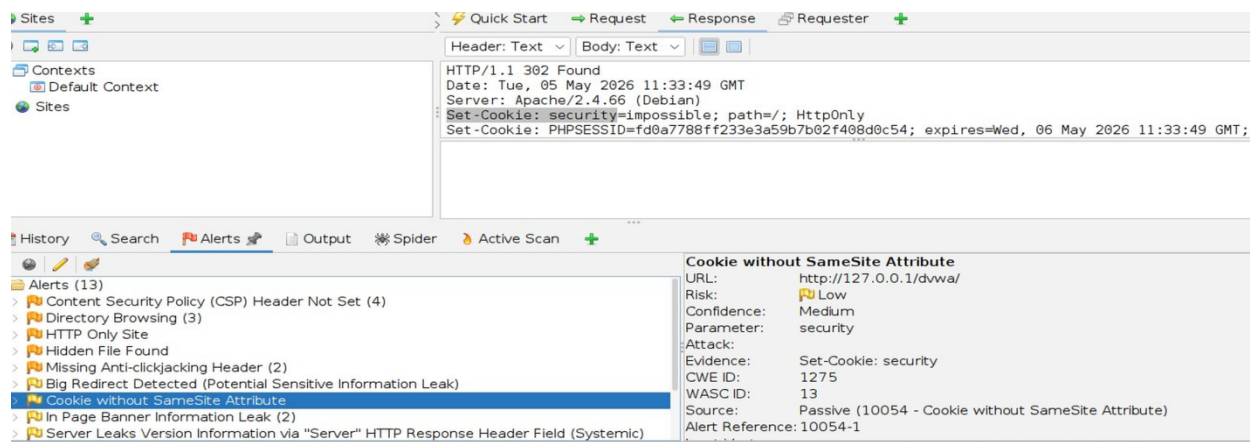


Figure 14: ZAP Alert — Cookie Without SameSite Attribute (CWE-1275)

Finding 11: X-Content-Type-Options Header Missing (LOW)

Risk Level	LOW
CWE / WASC	CWE-693 / WASC-15
Parameter	x-content-type-options
Tool	OWASP ZAP 2.17.0

Description: The X-Content-Type-Options: no sniff header is absent from server responses. Without this header, browsers may sniff the MIME type of responses, potentially leading to MIME confusion attacks where malicious content is executed as a different content type than intended.

Remediation:

- Add X-Content-Type-Options: no sniff to all HTTP responses in Apache configuration.

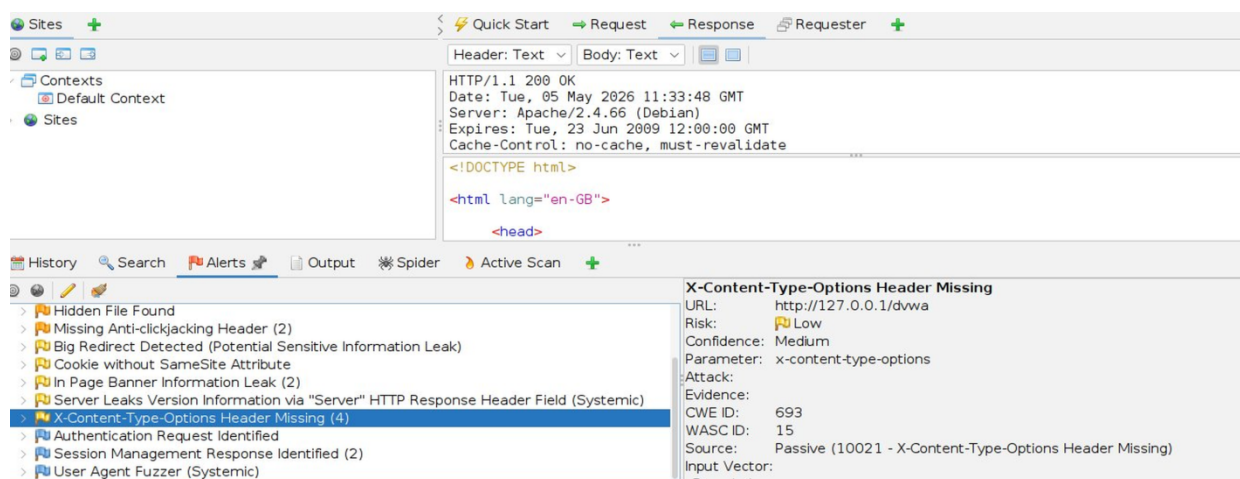


Figure 15: ZAP Alert — X-Content-Type-Options Header Missing

5. REMEDIATION SUMMARY

The following table provides a prioritized remediation plan for all identified vulnerabilities:

#	Vulnerability	Risk	Priority	Action
1	MySQL Port 3306 Exposed	HIGH	Immediate	Firewall rule + bind MySQL to 127.0.0.1
2	Login Over HTTP (No HTTPS)	HIGH	Immediate	Enable TLS/SSL + enforce HTTPS redirect
3	CSP Header Not Set	MEDIUM	Short-term	Add Content-Security-Policy header
4	Directory Browsing Enabled	MEDIUM	Short-term	Set Options -Indexes in Apache config
5	Hidden File (.git) Exposed	MEDIUM	Short-term	Block. git access + remove from web root
6	Missing Anti-Clickjacking Header	MEDIUM	Short-term	Add X-Frame-Options: SAMEORIGIN
7	Server Version Disclosure	MEDIUM	Short-term	Set ServerTokens Prod in Apache
8	Cookie Missing Secure/HttpOnly	MEDIUM	Short-term	Add Secure + HttpOnly cookie flags
9	Big Redirect Info Leak	LOW	Long-term	Minimize redirect response bodies
10	Cookie Missing SameSite	LOW	Long-term	Set SameSite=Strict on all cookies
11	X-Content-Type-Options Missing	LOW	Long-term	Add no sniff header to responses

6. CONCLUSION

This vulnerability assessment of the Damn Vulnerable Web Application (DVWA) identified 11 security vulnerabilities across three risk levels using Nmap, OWASP ZAP, and Browser DevTools. The findings demonstrate a range of common web application and network security weaknesses frequently encountered in real-world environments.

The two HIGH severity findings an exposed MySQL database port and plaintext transmission of credentials over HTTP represent the most critical risks and must be addressed immediately. The MEDIUM severity findings related to missing security headers, directory browsing, and cookie misconfiguration should be remediated on a short-term basis to significantly reduce the application's attack surface.

Implementing the recommended remediations will substantially improve the application's security posture. Regular vulnerability assessments should be scheduled to ensure continuous security improvement and alignment with best practices such as the OWASP Top 10 framework.

Report prepared by Angelo Bosco Samjela | CIN: FIT/APR26/CS7778 | Future Interns Cyber Security Internship | Task 1 | May 2026